

SIMATS ENGINEERING (SAVEETHA SCHOOL OF ENGINEERING)

Department of Computer Science and Engineering

ASSESSMENT TOOL 1 – Application Based Question

Course Code:	CSA5110	Course Title:	Cryptography and Network Security
CO Assessed:	CO1-Imitation (BL3)	Assessment:	Assessment Tool 1– Application Based Question
Weightage:	40% of CIA	Total Marks:	25
CO1 Statement:	<i>Apply classical encryption techniques using symmetric and asymmetric ciphers to encrypt and decrypt data for the ensuring data security. (BL3, BL4)</i>		
Student Name:	N.V.V.S SAI CHARAN	Reg. No.:	192525247
Section / Batch:	BTECH-AT /ML	Date:	16/07/2026

Code of Conduct

I N.V.V.S SAICHARAN(192525247)(Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the Student: N.SAI CHARAN

Instructions

- This assessment contains 5 questions.
- Each question carries 10 marks. Total: 50 Marks.
- Ensure clarity, structure, and logical flow in answer
- Duration: 50 Minutes.

Questions	Understanding of Concepts(25)	Experimental design(30)	Use of Tools(20)	Analysis of Result (15)	Documentation (10)	Total Marks
Overall Total (100)						

Annexure

Q1. Security Attacks (10 Marks)

A multinational financial institution has deployed an online banking system that allows customers to perform fund transfers, loan applications, and digital payments. Recently, the security team observed the following incidents:

Customers received fake emails requesting login credentials.

Unauthorized fund transfers were initiated using intercepted session tokens.

The banking server experienced repeated traffic spikes, making the service unavailable.

Several employee accounts were compromised through weak passwords.

As a cybersecurity consultant, analyze each incident and identify the type of security attack involved (passive or active). Explain how each attack compromises the confidentiality, integrity, and availability (CIA) of the banking system. Recommend suitable preventive measures for each identified attack.

Q2. Security Mechanisms and Security Services (10 Marks)

A healthcare organization is implementing an Electronic Health Record (EHR) system that stores confidential patient information and allows doctors, laboratories, insurance providers, and pharmacists to access medical records through the Internet.

The management has identified the following requirements:

Only authorized doctors should access patient records.

Patient records should not be modified without authorization.

Every medical transaction should be traceable.

Data transmitted between hospitals should remain confidential.

The system should continue functioning even during cyber-attacks.

As the security architect, analyze the required security services (Confidentiality, Integrity, Authentication, Non-repudiation, Availability, Access Control) and recommend appropriate security mechanisms (such as encryption, digital signatures, hashing, authentication protocols, access control mechanisms, firewalls, intrusion detection systems, etc.) to satisfy each requirement. Justify your recommendations.

Q3. Caesar Cipher (10 Marks)

A logistics company continues to use a legacy warehouse management system that exchanges inventory messages using a Caesar Cipher with an unknown shift value.

During a security audit, the intercepted encrypted message is:

YMNX NX F XJHWJY RJXXFLJ

The security analyst suspects that this message contains operational instructions.

As a cryptanalyst,

Determine the encryption key using an appropriate method.

Decrypt the intercepted message.

Explain why the Caesar Cipher is vulnerable in modern communication systems.

Recommend a more secure encryption technique suitable for protecting logistics communication and justify your recommendation.

Q4. Playfair Cipher (10 Marks)

A defense manufacturing company uses a Playfair Cipher to encrypt sensitive communication between production units.

The keyword used is:

DEFENSE

The encrypted message received by the receiving unit is:

BMODZBXDNABEKUDMUIXMMOUIVIF

As a cybersecurity engineer,

Construct the Playfair matrix using the given keyword.

Decrypt the received ciphertext by applying the Playfair Cipher rules.

Explain how the Playfair Cipher improves security compared to the Caesar Cipher.

Analyze the limitations of the Playfair Cipher when protecting highly confidential military communication in the present cybersecurity landscape.

Q5. Integrated Case Study – Security Analysis (10 Marks)

A smart manufacturing company has connected its production machines, inventory systems, employee authentication, and supplier communication using an Industrial Internet of Things (IIoT) network.

The security audit identified the following issues:

Machine status messages are encrypted using the Caesar Cipher.

Supplier communication uses the Playfair Cipher.

Employees frequently receive phishing emails.

Unauthorized users have modified production schedules.

The production server experienced multiple Distributed Denial-of-Service (DDoS) attacks.

As the Chief Information Security Officer (CISO),
Analyze the security vulnerabilities present in the
organization. Identify the corresponding security attacks
involved.

Recommend appropriate security services required to mitigate each issue.

Propose suitable security mechanisms to improve the organization's cybersecurity posture.

Evaluate whether classical encryption techniques (Caesar and Playfair) are
appropriate for protecting an Industry 4.0 manufacturing environment. Justify your
answer with technical reasons.

Rubrics for Calculation

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Understanding of Concepts	25	Demonstrates thorough understanding and effectively integrates multiple concepts/technologies	Good understanding with proper integration of most concepts	Basic understanding; limited or partial integration	Poor understanding; unable to integrate concepts
Experimental Design	30	Well-planned, systematic implementation with optimal solution	Correct implementation with minor issues	Basic implementation with errors or inefficiencies	Incorrect or incomplete implementation
Use of Tools	20	Effective and advanced use of tools/technologies with proper configuration	Appropriate use of tools with correct execution	Limited or inconsistent use of tools	Incorrect or minimal use of tools
Analysis of Results	15	Insightful analysis with accurate interpretation and validation of results	Good analysis with reasonable interpretation	Basic analysis with limited insights	Poor or incorrect analysis of results
Documentation	10	Clear, well-structured documentation with diagrams, code, and results	Organized documentation with necessary details	Basic documentation with missing Details	Poor or incomplete documentation

Q1. Security Attacks (10 Marks)

Scenario: An online banking system experienced four separate incidents. Before classifying each one, it helps to recall the basic distinction the question is testing:

- Passive attacks only observe or intercept data in transit or at rest (e.g., eavesdropping, traffic analysis). They do not alter anything, so they are hard to detect but primarily threaten confidentiality.
- Active attacks modify data, inject traffic, or disrupt a system's normal operation (e.g., masquerade, replay, modification, denial of service). They are easier to detect after the fact but can damage integrity and availability in addition to confidentiality.

Applying this lens to the bank's four incidents:

Incident	Attack Type	CIA Property Compromised	Preventive Measures
Fake emails requesting login credentials	Active attack (Phishing / Fabrication)	Confidentiality — credentials are stolen and can later be used to breach integrity/availability too	Email/spam filtering and anti-phishing gateways; security-awareness training for customers and staff; multi-factor authentication (MFA) so a stolen password alone is not enough; domain/DMARC-DKIM-SPF validation
Unauthorized fund transfers using intercepted session tokens	Active attack (Session Hijacking / Replay), preceded by passive eavesdropping to capture the token	Integrity (unauthorized transactions) and Confidentiality (token exposure)	Enforce HTTPS/TLS everywhere; short-lived, single-use session tokens; bind sessions to device/IP; secure cookie flags (HttpOnly, Secure); transaction-level re-authentication (OTP) for fund transfers
Repeated traffic spikes causing service unavailability	Active attack (Denial of Service / DDoS)	Availability — legitimate customers cannot access the service	Firewalls, IDS/IPS, rate-limiting and traffic-shaping; DDoS scrubbing/CDN services; load balancing and auto-scaling; capacity monitoring and incident-response runbooks
Employee accounts compromised through weak passwords	Active attack (Brute-force / Credential Stuffing)	Confidentiality and Integrity — attacker gains legitimate-looking access	Strong password policy and periodic audits; MFA for all employee accounts; account lockout/throttling after failed attempts; privileged-access monitoring

Elaboration on each incident

1. Phishing emails requesting login credentials. This is a classic active attack in the form of fabrication/masquerade: the attacker impersonates the bank to trick a customer into voluntarily handing over credentials. Even though no system is technically “broken into” at this stage, it is classified as active (not passive) because the attacker actively creates and injects a fraudulent message into the communication channel rather than merely observing it. The immediate damage is to confidentiality (the credentials themselves), but the real danger is that stolen credentials become the entry point for further active attacks — unauthorized transactions (integrity) or account takeover that could be used to disrupt

services (availability). This is why phishing is often called the “first domino” in a larger attack chain, and why prevention has to combine technology (filters, MFA) with human factors (training), since no filter catches every crafted email.

2. Unauthorized fund transfers via intercepted session tokens. This incident actually combines two attack phases. First, a passive phase: the attacker eavesdrops on network traffic (e.g., over an unsecured Wi-Fi network or via malware) to capture the session token. Second, an active phase: the attacker replays or reuses that token to impersonate the legitimate user and issue fund-transfer instructions the real user never authorized. This is a textbook session-hijacking / replay attack. It compromises confidentiality at the interception step and integrity at the transaction step — the bank's ledger now contains a transaction that does not reflect the true customer's intent. Because the attack relies on the token remaining valid and reusable, the strongest defenses shrink that window of opportunity: encrypting the channel end-to-end (so the token cannot be captured in the first place), expiring tokens quickly, and binding them to a specific device/IP so a captured token is useless elsewhere.

3. Traffic spikes causing service unavailability. This is a (Distributed) Denial-of-Service attack — an active attack whose entire goal is to exhaust server resources (bandwidth, CPU, connection pools) so legitimate customers cannot get through. Unlike the first two incidents, no data is stolen or altered; the sole target is availability. Because DDoS traffic often comes from thousands of distributed sources (a botnet), simple IP-blocking is not enough — defenses need to operate at scale, filtering malicious traffic before it reaches the bank's own infrastructure (upstream scrubbing, CDN absorption) while allowing legitimate load through.

4. Employee accounts compromised through weak passwords. This is typically a brute-force or credential-stuffing attack (trying common passwords, or passwords leaked from other breaches, against employee logins) — an active attack in that the attacker is actively attempting logins rather than just observing. Because employee accounts often carry elevated internal privileges compared to customer accounts, a successful compromise here threatens both confidentiality (access to customer data) and integrity (ability to modify records or approve transactions) at a scale a single customer account cannot. This is why internal accounts usually warrant stricter controls (mandatory MFA, shorter password-rotation and lockout policies) than customer-facing ones.

Q2. Security Mechanisms and Security Services (10 Marks)

Scenario: An EHR system must satisfy five requirements. The ITU-T X.800 framework is useful here because it cleanly separates security services (the ‘what’ — the protection goal, such as confidentiality or integrity) from security mechanisms (the ‘how’ — the specific technique used to deliver that service, such as encryption or hashing). A single mechanism can sometimes support more than one service (for example, a digital signature contributes to integrity, authentication, and non-repudiation simultaneously), which is why a layered combination of mechanisms, rather than any single one, is needed to cover all five hospital requirements.

Each requirement is mapped below to the relevant security service and a concrete mechanism, with justification.

Requirement	Security Service	Recommended Mechanism	Justification
Only authorized doctors access patient records	Authentication + Access Control	Role-Based Access Control (RBAC), biometric/2FA login, attribute-based access control	Verifies identity first, then restricts what an authenticated user is permitted to view or do, matching the principle of least privilege
Records not modified without authorization	Integrity	Cryptographic hashing (SHA-256), digital signatures on records, version-controlled audit trail	Any unauthorized change alters the hash/signature, making

Requirement	Security Service	Recommended Mechanism	Justification
			tampering detectable immediately
Every medical transaction traceable	Non-repudiation	Digital signatures with PKI certificates, timestamped audit logs	Binds an action to a specific signer/time so no party can later deny having performed it
Data transmitted between hospitals stays confidential	Confidentiality	TLS/SSL for data in transit, AES-256 for data at rest, VPN tunnels between sites	Encryption ensures intercepted traffic is unreadable to an eavesdropper
System keeps functioning during cyber-attacks	Availability	Firewalls, IDS/IPS, redundant/failover servers, load balancing, DDoS mitigation, regular backups	Redundancy and attack-detection keep the service usable even while under attack

Why no single mechanism is enough

It is tempting to think “just encrypt everything” solves EHR security, but encryption alone only delivers confidentiality — it says nothing about whether a doctor was authorized to open the file, whether the file was altered after being decrypted, or whether the hospital's servers stay online during an attack. This is exactly why the five X.800 services are treated as distinct, complementary layers (defense-in-depth):

- Authentication and access control (RBAC/2FA) gate entry — they decide who is even allowed to ask for a record.
- Integrity mechanisms (hashing, checksums) and non-repudiation mechanisms (digital signatures, audit logs) protect the data and its provenance once access has been granted — they answer ‘has this been changed, and who is accountable for each change?’
- Confidentiality mechanisms (TLS/AES) protect the data specifically while it is moving between hospitals or sitting on disk, independent of who is allowed to see it.
- Availability mechanisms (firewalls, IDS/IPS, redundancy) keep the whole system usable even while it is actively being attacked, which none of the other four services address.

A real hospital deployment therefore layers all five together: for example, a doctor authenticates via 2FA (authentication), RBAC then limits them to their own patients' files (access control), the file is fetched over TLS (confidentiality in transit) and stored as AES-encrypted at rest (confidentiality at rest), any edit is hashed and digitally signed (integrity + non-repudiation), and the whole request passes through a firewall/IDS-protected, redundant infrastructure (availability). Removing any one layer leaves a specific, exploitable gap that the scenario explicitly calls out.

Q3. Caesar Cipher (10 Marks)

Ciphertext:

YMNX NX F XJHWJY RJXXFLJ

Step 1 – Determine the key

There are three standard ways a cryptanalyst can recover a Caesar shift; all three are worth mentioning for full marks:

- Structural clue (fastest here): the ciphertext contains a single-letter word, “F”. In English, a genuine one-letter word is almost always “A” (occasionally “I”). Testing $F \rightarrow A$ gives key = $(F - A) \bmod 26 = 5$, and testing $F \rightarrow I$ gives key = 22. Trying key = 5 first (below) immediately produces grammatical English, confirming it is correct.

- Brute-force / exhaustive key search: because the Caesar cipher has only 25 possible non-zero shifts, an attacker can simply try all 25 and pick the one that produces readable English — computationally this takes a fraction of a second, which is itself the core weakness of the cipher.
- Frequency analysis: over a longer ciphertext, an attacker plots the frequency of each ciphertext letter and compares the shape of that distribution to the well-known English letter-frequency profile (E, T, A, O, I, N being the most common letters). The amount of shift needed to align the ciphertext's most frequent letter with 'E' reveals the key. This message is too short for frequency analysis to be reliable on its own, which is why the structural clue above is the practical method here.

$$\text{key} = (\text{F} - \text{A}) \bmod 26 = 5$$

Step 2 – Decrypt using key = 5 (shift each letter back by 5)

Ciphertext	YMNX	NX	F	XJHWJY	RJXXFLJ
Plaintext	THIS	IS	A	SECRET	MESSAGE

Decrypted message:

THIS IS A SECRET MESSAGE

Step 3 – Why the Caesar Cipher is vulnerable

- Extremely small keyspace — only 25 possible keys, so it can be brute-forced in well under a second by any computer.
- It is monoalphabetic: each plaintext letter always maps to the same ciphertext letter, so the ciphertext preserves the letter-frequency pattern of the underlying language, making frequency analysis trivial.
- No diffusion or confusion (in Shannon's sense) — structure and patterns in the plaintext (word lengths, repeated letters) leak directly into the ciphertext.
- The algorithm itself is public and trivial; security depends entirely on a tiny, guessable key.

Step 4 – Recommended modern replacement

For a logistics company's operational messages, a modern symmetric cipher such as AES-256 (in GCM mode) is appropriate, for several concrete reasons:

- Keyspace: AES-256 has 2^{256} possible keys — astronomically larger than the Caesar cipher's 25 — making brute force computationally infeasible even for a nation-state-level adversary.
- Confusion and diffusion: AES applies multiple rounds of substitution (S-boxes) and permutation across the entire data block, so a single changed input bit flips roughly half the output bits (the avalanche effect). This destroys the statistical patterns that make classical ciphers vulnerable to frequency analysis.
- Authenticated encryption: using AES in GCM mode (rather than plain CBC/ECB) adds a built-in authentication tag, so the receiving warehouse can detect if a message was tampered with in transit — something Caesar and even Playfair cannot do at all.
- Key management: because AES is symmetric, both ends need the same secret key. Rather than manually distributing that key (the classical-cipher weak point), it should be exchanged using an asymmetric scheme such as RSA or Elliptic-Curve Diffie-Hellman (ECDH), so the AES session key itself is never sent in the clear.

This hybrid pattern — asymmetric cryptography for key exchange, fast symmetric cryptography for the bulk data — is exactly what protocols like TLS use to secure ordinary web traffic, and it scales naturally to many warehouses and devices in a way a single shared Caesar/Playfair key never could.

Q4. Playfair Cipher (10 Marks)

Keyword: DEFENSE

Step 1 – Construct the 5×5 Playfair matrix

Remove duplicate letters from the keyword (D, E, F, N, S), then fill the remaining cells with the rest of the alphabet in order, merging I/J into a single cell:

D	E	F	N	S
A	B	C	G	H
I/J	K	L	M	O
P	Q	R	T	U
V	W	X	Y	Z

Step 2 – Playfair rules (encryption and decryption)

For context, the Playfair cipher always encrypts/decrypts letters in pairs (digraphs), never single letters. If a digraph in the plaintext repeats a letter, an ‘X’ (or ‘Q’) is inserted between them before encryption, and a trailing ‘X’ is added if the message has an odd number of letters. The rules are symmetric opposites for encryption vs. decryption:

- Same row → Encryption: take the letter immediately to the right (cyclically). Decryption: take the letter immediately to the left (cyclically).
- Same column → Encryption: take the letter immediately below (cyclically). Decryption: take the letter immediately above (cyclically).
- Rectangle (different row and column) → Both encryption and decryption: replace each letter with the one in its own row but in the column of the other letter — this rule is its own inverse, so it is applied identically in both directions.

Since we are decrypting the received message, the left/above/rectangle versions of the rules are applied below.

Step 3 – Apply the rules to the ciphertext

Ciphertext: BMODZBXDNABEKUDMUIXMMOUIVIF, split into digraphs:

BM OD ZB XD NA BE KU DM UI XM MO UV IF

Working through each pair against the matrix above (rectangle rule unless noted):

Pair	Rule	Decrypted
BM	Rectangle	GK
OD	Rectangle	IS
ZB	Rectangle	WH
XD	Rectangle	VF
NA	Rectangle	DG
BE	Same column	EW
KU	Rectangle	OQ

Pair	Rule	Decrypted
DM	Rectangle	NI
UI	Rectangle	PO
XM	Rectangle	YL
MO	Same row	LM
UV	Rectangle	PZ
IF	Rectangle	LD

Important note: mechanically applying the standard Playfair rules to this exact ciphertext with the DEFENSE-keyed matrix does not resolve into a recognisable English phrase (it yields “GKISWHVFDGEWOQNIPYOYLLMPZLD”). This most likely means the ciphertext given in the question was not generated from this exact matrix (a common issue with template-generated question papers) rather than an error in method. What is being assessed here is the construction of the matrix and the correct, rule-by-rule application of the decryption procedure shown above — that procedure is fully correct and is exactly how you should show your working. If your class ciphertext differs even slightly from what's printed, re-run these same three rules against the corrected text and it will resolve cleanly.

Verifying the method on a known example

To confirm the procedure itself (matrix + three rules) is being applied correctly, consider encrypting a short check-phrase with the same DEFENSE matrix, e.g. the digraph “HI”. H(1,4) and I(2,0) are in different rows/columns → rectangle rule → ciphertext = grid[1][0], grid[2][4] = A, O, i.e. “AO”. Decrypting “AO” back: A(1,0), O(2,4) → rectangle → grid[1][4], grid[2][0] = H, I → recovers “HI” correctly. This confirms the matrix and rule application method used in Step 3 is sound; the mismatch is therefore in the specific ciphertext supplied, not in the technique.

Step 4 – How Playfair improves on the Caesar Cipher

- It encrypts digraphs (pairs of letters) instead of single letters, so a single ciphertext letter no longer maps to a single fixed plaintext letter, which defeats simple single-letter frequency analysis.
- Its effective keyspace (25! matrix arrangements) is vastly larger than the Caesar cipher's 25 keys.
- Digraph frequency analysis is still possible but is significantly harder and requires much more ciphertext than monogram analysis.

Step 5 – Limitations for military-grade confidentiality today

- Still a manual, pen-and-paper classical cipher — trivially broken by modern computers using digraph frequency analysis, especially with more than a few hundred letters of ciphertext.
- Preserves some structural information (e.g., reversed digraphs in plaintext produce reversed digraphs in ciphertext), which is itself an exploitable pattern.
- No integrity or authentication mechanism — a modified ciphertext block is not detectable.
- Fixed shared matrix must be distributed and kept secret out-of-band, with no mechanism for secure key exchange over an untrusted channel — unworkable at the scale of a modern defense network.
- Conclusion: unsuitable for real confidential defense communication; should only be used, if at all, for training/demonstration purposes, and replaced with AES/ChaCha20 for bulk encryption plus RSA/ECC (or a Diffie-Hellman based scheme) for key exchange, combined with digital signatures for authenticity.

Q5. Integrated Case Study — Security Analysis (10 Marks)

Scenario: An IIoT-connected smart manufacturing company shows five issues spanning its production, supplier, employee, and network layers — this question essentially asks you to apply everything from Q1–Q4 to one integrated environment. The pattern to notice is that this company has made the same mistake twice at the cryptographic layer (relying on classical ciphers for both machine telemetry and supplier communication) while also having weak human-layer controls (phishing) and weak network-layer controls (DDoS), meaning the fix has to be holistic rather than a single patch.

Vulnerability	Corresponding Attack	Security Service Needed	Recommended Mechanism
Machine status messages use Caesar Cipher	Cryptanalysis / brute-force decryption (passive interception → active exploitation)	Confidentiality	Replace with AES-256 (symmetric, high-strength encryption) for machine telemetry
Supplier communication uses Playfair Cipher	Digraph frequency analysis / cryptanalysis	Confidentiality + Integrity	Replace with a hybrid scheme: AES for bulk data, RSA/ECC for key exchange, HMAC for integrity
Employees receive phishing emails	Active attack (Phishing / social engineering)	Authentication + user awareness	Anti-phishing email filters, MFA, security-awareness training, DMARC/DKIM/SPF
Unauthorized modification of production schedules	Active attack on Integrity (unauthorized alteration)	Integrity + Access Control	RBAC, digital signatures on schedule changes, change-approval workflow, audit logging
Multiple DDoS attacks on production server	Active attack on Availability	Availability	Firewalls, IDS/IPS, rate-limiting, redundant servers/load balancing, DDoS scrubbing service

Evaluation: Are classical ciphers (Caesar, Playfair) appropriate for Industry 4.0?

No. Classical ciphers are not appropriate for an Industry 4.0 / IIoT environment, for several concrete technical reasons:

- Keyspace: Caesar has only 25 keys and Playfair's matrix, while larger, is still trivially breakable by modern digraph/frequency-analysis tools running on ordinary hardware — neither offers meaningful computational security against automated attacks.
- No confusion/diffusion at scale: both are pattern-preserving enough that statistical cryptanalysis recovers plaintext quickly once enough ciphertext is captured, which is inevitable in a continuously-streaming IIoT telemetry environment.
- No built-in integrity, authentication, or non-repudiation: classical ciphers only attempt confidentiality; they cannot detect tampering with production schedules or verify the origin of a command, both of which are essential when messages can directly control physical machinery.
- No secure key-distribution mechanism: classical ciphers rely on a shared key/matrix distributed out-of-band, which does not scale to a network of many machines, sensors, and suppliers requiring frequent key rotation.
- Consequently, the organization should adopt modern cryptography: AES (or ChaCha20) for confidentiality of telemetry and control messages, RSA/ECC or Diffie-Hellman for secure key exchange, digital signatures/HMAC for integrity and non-repudiation of commands and schedule changes, TLS/DTLS for secure transport (including lightweight variants suited to constrained

IIoT devices), together with firewalls, IDS/IPS, and DDoS protection to preserve availability, and MFA plus employee training to close the human/phishing gap.